

IQA AI SECURITY THREAT MODEL REPORT

AI Security Analysis

Classification: Confidential : For Internal Security Information Only

Report Timestamp

12 June 2026, 22:00 CEST

Compiled by: Natacha B. and IQA MLOps Project Team

Report Reference: IQA SEC TM MVP 1206 v2

Report Content

This report defines the MVP threat model for the IQA MLOps project. It focuses on the security and governance risks that can affect prediction, feedback, candidate dataset creation, model promotion, model reload, auditability, and the integrity of the Feature AE lifecycle.

This updated version adds visual threat model diagrams and maps the IQA MVP threats to OWASP Machine Learning Security Top 10, MITRE ATLAS, and selected MITRE ATT&CK infrastructure concepts. The scope remains deliberately practical so Phase 1 and Phase 2 remain feasible before the 19 June milestone.

Executive Summary and analysis

System Overview

IQA is a computer vision quality assistant for industrial Casting parts. The MVP does not replace Sophie. It provides a decision support workflow with traceability, feedback, model versioning and controlled lifecycle management. The main security objective is to prevent unsafe feedback, unsafe training data, unapproved model reloads and loss of traceability from influencing the live prediction system.

Component	Role in MVP	Main security risk	MVP control
FastAPI	Prediction, feedback, model version and reload routes	Invalid requests or unauthorized reload	Strict schemas, admin token for reload, audit logs
PostgreSQL metadata	Predictions, feedbacks, lots, incidents and model versions	Loss of traceability	Every prediction links to sha256, piece_event, scenario, lot and model
MLflow Registry	Source of truth for model promotion	Wrong model marked as production	Only MLflow stage prod can be reloaded
MinIO	Artifact storage for models, heatmaps and datasets	Artifact mismatch or unauthorized access	MinIO stores artifacts but never decides promotion status
Feature AE	Only living model in the MVP	Training contamination	Good only candidate datasets with ROI ok only
ROI segmenter	Fixed ROI extractor	ROI failure hiding a defect	ROI warning gives Orange minimum, ROI fail requires review
Feedback system	Oracle GT and human Sophie feedback	Feedback poisoning	GT sovereign for train eligibility, human priority for display decision

Visual Threat Model Diagrams

The following diagrams are included to make the threat model usable by both technical reviewers and management stakeholders. They show where trust boundaries exist, how data moves through the model lifecycle, and where controls block the highest impact attack paths.

Figure 1. IQA MVP Trust Boundaries and Attack Surface

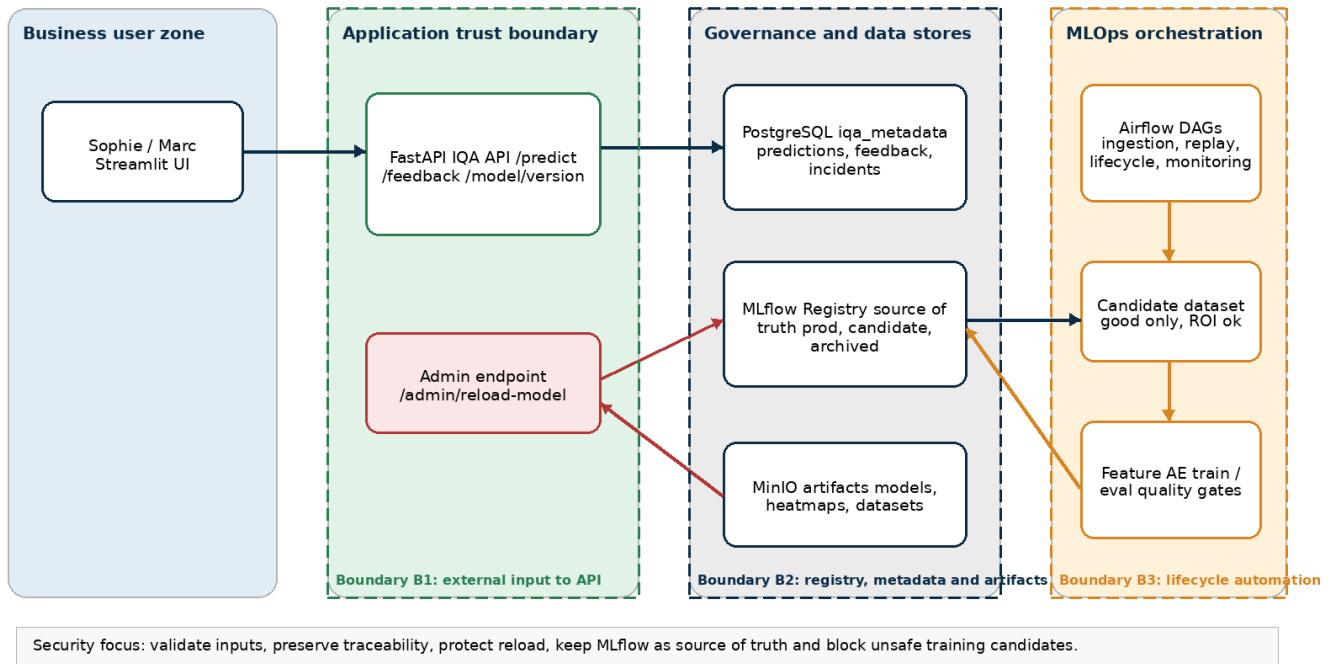


Figure 1 - Architecture and trust boundaries for the IQA MVP attack surface.

Figure 2. IQA Data and Model Lifecycle with Control Gates

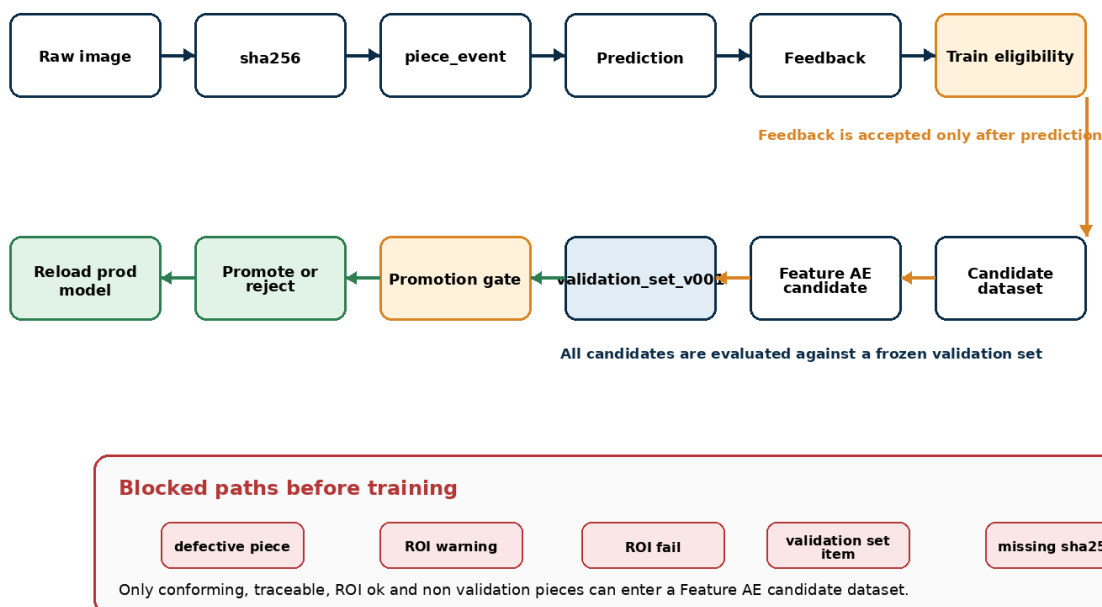


Figure 2 - Data and model lifecycle with training eligibility and promotion gates.

Analytical Framework

This threat model uses OWASP Machine Learning Security Top 10 as the primary AI specific risk reference. The most relevant categories for IQA are ML01 Input Manipulation Attack, ML02 Data Poisoning Attack, ML06 AI Supply Chain Attacks, ML08 Model Skewing, ML09 Output Integrity Attack and ML10 Model Poisoning.

MITRE ATLAS is used as the adversarial AI TTP reference. The mapping is intentionally kept at tactic or pattern level in this MVP document to avoid false precision. MITRE ATT&CK is used only for traditional infrastructure surfaces such as credentials, admin access, service abuse and deployment hardening.

The analysis is also informed by practical AI security training and previous applied experimentation in adversarial AI, data integrity and model robustness. These inputs are used to enrich the scenarios, but the implementation remains scoped to controls that can be delivered during Phase 1 and Phase 2.

The OWASP Top 10 for Large Language Model Applications is not used as the primary reference because IQA is not an LLM application. LLM specific risks such as prompt injection are therefore outside this MVP threat model unless a future LLM assistant is added to the product.

Key Assets to Protect

Asset	Why it matters	Protection objective
Raw images	Industrial data and source of predictions	Integrity, traceability, no arbitrary path access
sha256	Evidence of file integrity	Mandatory in manifests and prediction logs
piece_event	Atomic unit for split, feedback and decision	No split leakage between train, replay and validation
validation_set_v001	Frozen reference for gates	Never used for train, replay or calibration
candidate dataset	Input for Feature AE retraining	Good only, ROI ok, no defective, no validation set
feedback	Controls train eligibility and decision review	Feedback after prediction only, conflict logging
model registry	Production model source of truth	MLflow Registry controls candidate, prod and archived states
reload endpoint	Changes active model	Admin only, scenario_id required, every attempt logged

Threat Overview

ID	Threat	Impact	Priority	Core MVP control
T1	Feedback poisoning	Feature AE learns defective parts as normal	P1	GT sovereign for train eligibility, feedback after prediction
T2	Abusive model reload	API serves an unapproved model	P1	Admin token, MLflow prod only, reload audit
T3	Invalid prediction request	Untraceable or incorrect prediction	P1	Manifest based resolution, known scenario_id, sha256 required
T4	Candidate dataset contamination	Normality model becomes unsafe	P1	Good only, ROI ok, no defective, no validation set
T5	MLflow and MinIO confusion	Registry and artifact store disagree	P1	MLflow Registry is source of truth
T6	Scenario collision	Wrong prod model used for the wrong scenario	P2	Registered model per scenario
T7	False negative not blocking promotion	Unsafe model promoted	P1	False negative creates critical incident and blocks promotion
T8	ROI warning or fail ignored	Defect outside ROI not reviewed	P1	ROI warning gives Orange minimum, ROI fail requires review
T9	Oracle GT and human conflict	Wrong data enters train if conflict is not handled	P2	Human priority for display, GT priority for train
T10	Secret exposure	Unauthorized access to services or admin routes	P2	No secrets in Git, .env only, token from environment

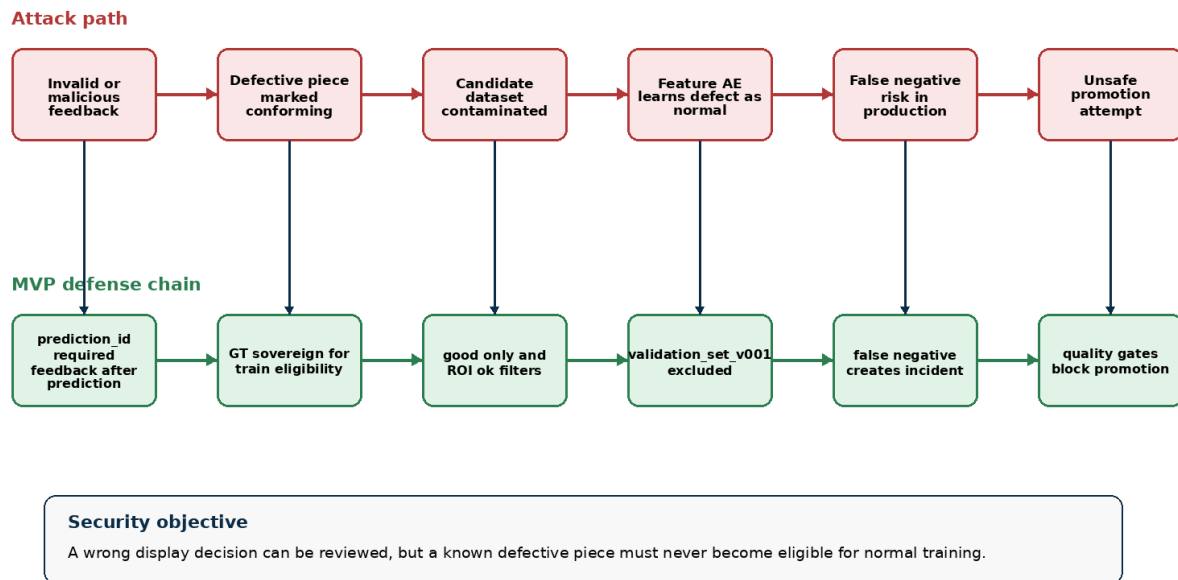
OWASP ML, MITRE ATLAS and ATT&CK Mapping

IQA threat	OWASP ML Security Top 10	MITRE ATLAS or ATT&CK lens	Interpretation for IQA
T1 Feedback poisoning	ML02 Data Poisoning, ML10 Model Poisoning	ATLAS: attack staging, poisoning oriented manipulation	Feedback can influence what becomes training data.
T2 Abusive model reload	ML06 AI Supply Chain Attacks, ML09 Output Integrity Attack	ATLAS: model access and impact; ATT&CK: credential access and impact	Reload can replace the active model if not controlled.
T3 Invalid prediction request	ML01 Input Manipulation Attack, ML09 Output Integrity Attack	ATLAS: evasion and impact	Untrusted identifiers or paths can produce non traceable predictions.
T4 Candidate dataset contamination	ML02 Data Poisoning, ML10 Model Poisoning	ATLAS: attack staging and poisoning	The candidate dataset is the main poisoning entry point.
T5 MLflow and MinIO confusion	ML06 AI Supply Chain Attacks	ATLAS: model supply chain integrity; ATT&CK: defense evasion	Registry and artifact store inconsistency breaks auditability.
T6 Scenario collision	ML08 Model Skewing, ML09 Output Integrity Attack	ATLAS: impact through context mismatch	A model trained for one scenario is used in another.
T7 False negative not blocking promotion	ML09 Output Integrity Attack	ATLAS: impact	An unsafe model is promoted despite known defect misses.
T8 ROI warning or fail ignored	ML01 Input Manipulation Attack, ML09 Output Integrity Attack	ATLAS: evasion and impact	A bad ROI can hide defects or reduce review priority.
T9 Oracle GT and human conflict	ML02 Data Poisoning, ML08 Model Skewing	ATLAS: attack staging and governance weakness	Display decision and training eligibility must remain separate.
T10 Secret exposure	ML06 AI Supply Chain Attacks	ATT&CK: credential access, initial access	Secrets can enable access to registry, storage or admin routes.

Note: the mapping is intentionally risk based and MVP focused. It is not a full ATLAS technique ID mapping. A later version can add exact technique IDs after the implementation and telemetry are stable.

Tactics, Techniques, and Procedures

TTPs	Notes
Tactics	Manipulate feedback, poison candidate datasets, force reload of an unapproved model, break traceability, hide ROI failures, or create scenario confusion.
Techniques	Submit feedback without a valid prediction, mark defective parts as conforming, call admin reload without authorization, use unknown scenario ids, bypass manifests with arbitrary paths, or rely on MinIO state instead of MLflow stage.
Procedures	A threat actor or faulty workflow first creates or exploits a weak control point, then causes the pipeline to accept unsafe feedback or unsafe candidate data, then pushes a model toward promotion or reload without reliable evidence and traceability

Figure 3. Feedback Poisoning Attack Path and MVP Defenses*Figure 3 - Feedback poisoning attack path and the MVP defense chain.*

Detailed Threat Scenarios and Controls

T1 Feedback poisoning

A feedback record marks a defective piece as conforming and makes it eligible for normal training. The control is to require a valid prediction id, accept feedback only after prediction, keep GT sovereign for train eligibility, and log every conflict between human Sophie and oracle GT.

T2 Abusive model reload

A model reload is triggered for a candidate or rejected model. The control is to protect the reload endpoint with an admin token, require scenario id, query MLflow Registry as the source of truth, and allow reload only for prod stage.

T3 Invalid prediction request

A request uses an unknown piece_event, an unknown scenario or an arbitrary image path. The control is to resolve all images from manifests, require sha256, reject unknown identifiers and return explicit errors.

T4 Candidate dataset contamination

A defective piece, ROI warning, ROI fail or validation set item enters the candidate dataset. The control is to enforce good only, ROI ok only, feedback conforme valide, sha256 present and validation set exclusion.

T5 MLflow and MinIO confusion

MLflow says one model is prod while MinIO points to another artifact. The control is to make MLflow Registry the only source of truth. MinIO remains an artifact store.

T6 Scenario collision

A model promoted in the drift scenario becomes active in the natural scenario. The control is to use one registered model per scenario and require scenario id for predict and reload.

T7 False negative not blocking promotion

A candidate misses a defective piece and is still promoted. The control is to create a critical incident and block promotion whenever a false negative is detected.

T8 ROI warning or fail ignored

A bad ROI allows a risky prediction to appear safe. The control is to force Orange minimum for ROI warning, mandatory review for ROI fail, and exclude both from training.

T9 Oracle and human conflict

Human Sophie marks a GT defective piece as conforming. The display decision may follow Sophie, but train eligibility remains controlled by GT and the conflict is logged.

T10 Secret exposure

A token or password is committed. The control is to keep real secrets out of Git, use .env locally, keep .env.example sanitized and review secrets before commit.

Security Control Matrix

Control area	Decision	Phase 1 status	Phase 2 implementation target
Feedback	Feedback after prediction only, prediction id required	Documented	API validation and tests
Human and GT	Human Sophie priority for display, GT priority for train eligibility	Documented	Conflict logging and metrics
Candidate dataset	Good only, ROI ok, no defective, no validation set	Documented	candidate_builder tests
Model reload	Admin only and MLflow prod only	Documented	Admin token and reload tests
Registry	MLflow Registry is source of truth	Documented	MLflow client checks
Scenario isolation	Registered model per scenario id	Documented	Predict and reload require scenario id
ROI safety	ROI warning Orange minimum, ROI fail review required	Documented	Incident and metrics
Secrets	No real secret in Git	Documented	CI check and .env.example review

Figure 4. Model Reload Governance and Refusal Paths

Decision principle: MLflow Registry is the only source of truth. MinIO stores artifacts only.

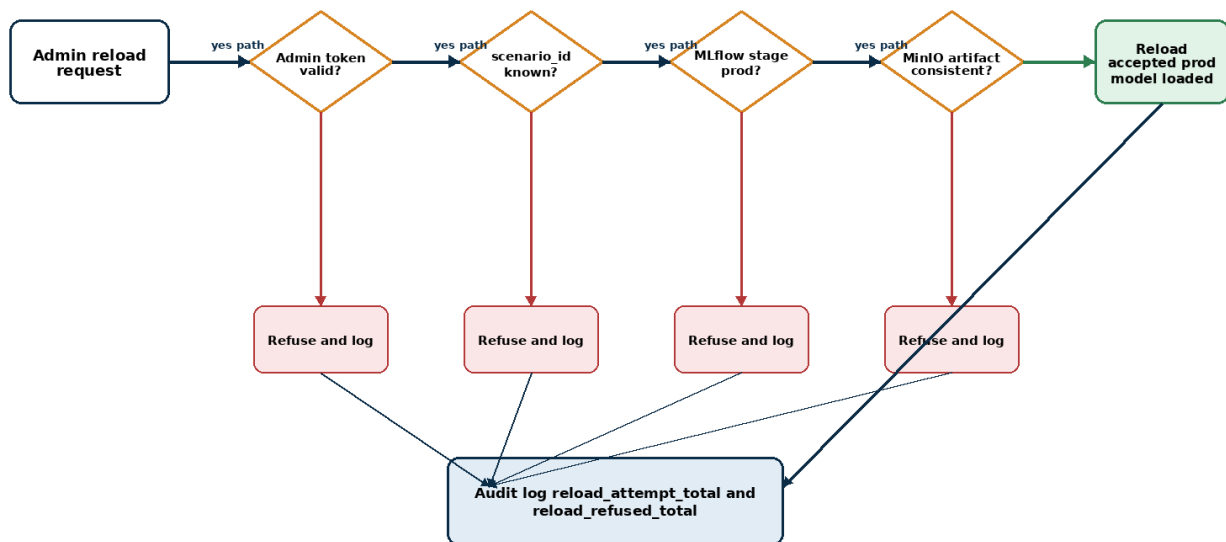


Figure 4 - Model reload governance with refusal and audit paths.

Planned Security Tests

Test name	Purpose
test_feedback_requires_prediction_id	Reject feedback that is not linked to a valid prediction
test_human_sophie_overrides_display_decision	Ensure human decision is visible when it differs from oracle
test_gt_blocks_train_eligibility	Ensure GT defective never enters normal training
test_defective_never_enters_candidate_dataset	Protect Feature AE training from defective pieces
test_roi_warning_never_enters_candidate_dataset	Exclude ROI warning from normal train
test_roi_fail_never_enters_candidate_dataset	Exclude ROI fail from normal train
test_validation_set_never_enters_train	Protect validation_set_v001 from leakage
test_reload_requires_admin_token	Reject unauthorized reload attempts
test_reload_only_loads_mlflow_prod	Ensure reload follows MLflow prod stage
test_scenario_id_is_required_for_prediction	Avoid scenario collisions
test_false_negative_creates_critical_incident	Block promotion after false negative
test_feedback_conflict_is_logged	Record human versus oracle conflicts

Security Metrics for Phase 2

Metric	Security meaning
ai_security_incidents_total	Total number of AI security incidents
feedback_conflict_total	Human Sophie and oracle GT conflicts
unsafe_train_candidate_blocked_total	Unsafe training candidates rejected
reload_attempt_total	All model reload attempts
reload_refused_total	Rejected reload attempts
false_negative_incident_total	False negatives detected in validation or replay
roi_warning_total	ROI warning events
roi_fail_total	ROI fail events
invalid_prediction_request_total	Invalid prediction requests rejected

Gaps and Questions

- Which minimal admin token mechanism will be used for reload during the MVP demonstration?
- Which PostgreSQL tables are final for predictions, feedback, incidents and model versions?
- How will MLflow Registry and MinIO artifact consistency be checked before reload?
- Which security metrics will be exposed through Prometheus during Phase 2?
- Which controls remain documentation only until the Z420 Ubuntu deployment is available?
- How will the team document rejected candidates and blocked unsafe training samples during the demo?

Conclusion and Recommendation

The IQA MVP contains several high impact AI security risks because feedback, model lifecycle, candidate dataset construction and model reload all influence the behavior of the live prediction system. The most critical risks are feedback poisoning, candidate dataset contamination, false negative promotion, model reload abuse and loss of traceability.

- **Threat Level:** **High**
- **Recommended Actions:**
- Keep MLflow Registry as the single source of truth for model promotion and reload.
- Never allow a defective, ROI warning, ROI fail or validation set item into the Feature AE normal training dataset.
- Use human Sophie as the priority for displayed decision, but keep GT sovereign for train eligibility.
- Protect admin reload with a token and log every reload attempt, including refused reloads.
- Expose AI security metrics in Phase 2 and make false negatives, ROI failures and feedback conflicts visible.
- Treat an imperfect Feature AE as acceptable only if the governance loop rejects unsafe candidates correctly.

Phase 1 and Phase 2 Feasibility Notes

This report deliberately separates documentation controls from implementation controls. Phase 1 produces the threat model, security controls configuration and security test backlog. Phase 2 implements the API validation, metrics, tests and reload controls once the API routes, candidate builder and model registry client are available.

The scope avoids heavyweight security components that would threaten the schedule. Full RBAC, WAF integration, advanced container scanning and production grade secret management are future hardening topics. The MVP keeps the security story focused on the AI risks that can realistically be demonstrated before the 19 June milestone.

Phase 1 Implementation Checklist

Item	Expected output
Threat model report	docs/security/threat_model_mvp.md and this Word report validated
Security controls config	configs/security_controls.yaml committed
Security tests backlog	tests/security/README_security_tests.md committed
Pull request	Branch naty/security-threat-model opened for review
Review points	GT train sovereignty, admin reload, MLflow source of truth and scenario isolation validated by team

Next Actions

- Validate the threat model choices with Adrien, Ken and Missy before implementing API controls.
- Use security_controls.yaml as the reference for Phase 2 API validation and tests.
- Convert planned tests into pytest files once the API routes and candidate builder are available.
- Update the planning file only after the pull request is reviewed or merged.

Sources and Analytical References

Reference	Use in this report
OWASP Machine Learning Security Top 10	Primary AI security risk categories for machine learning systems. This report uses the 2023 draft categories as a practical risk taxonomy.
MITRE ATLAS	Primary adversarial AI TTP reference for AI enabled systems. Used at tactic and pattern level in this MVP version.
MITRE ATT&CK	Traditional infrastructure threat reference used only for credential, access, deployment and service abuse surfaces.
IQA project planning and security discussions	Internal source for IQA data lifecycle, Feature AE governance, reload rules and Phase 1 or Phase 2 delivery constraints.